ISO/IEC 27701:2025

TABLA A.1 — CONTROLES PARA RESPONSABLES DE PII (CONTROLLERS)

Conditions for Collection and Processing

INFORME INTEGRAL DE IMPLEMENTACIÓN Y AUDITORÍA

Caso de Estudio: Universidad Nacional de San Agustín de Arequipa (UNSA)

DATOS DE LA ASIGNATURA Y AUDITORÍA:

- Institución Evaluada: Universidad Nacional de San Agustín de Arequipa (UNSA)
- Alcance Normativo: Controles A.1.2.2 al A.1.2.9 (Condiciones de Recolección y Tratamiento)
- Marco Jurídico Peruano: Ley N° 29733, D.S. 016-2024-JUS, Ley N° 27806, Ley 30220
- Rol del Auditor: Ing. Rafael (MSc. Ciberseguridad & Auditoría TI, Lead Auditor ISO)
- Enfoque de Entrega: Doble Perspectiva (Gestión Universidad 5W + Auditoría) y Guiones Orales

Arequipa, Perú — Semestre Académico 2026

Marco Metodológico y Estructura del Informe

El presente informe aborda el estándar internacional ISO/IEC 27701:2025 (Sistema de Gestión de Privacidad de la Información - PIMS), enfocado en la Tabla A.1 ('Condiciones para la recolección y tratamiento de PII'). La norma internacional exige demostrar que todo tratamiento de información personal es lícito, fundado en bases legales válidas en el Perú (Ley N° 29733 y D.S. 016-2024-JUS) y orientado a propósitos legítimos y explícitos.

Para garantizar un análisis riguroso y de utilidad práctica para el estudiante y el auditor, cada uno de los 8 controles (A.1.2.2 al A.1.2.9) se aborda en una página dedicada con 5 dimensiones clave:

- **1. Explicación General:** Concepto en palabras sencillas y analogía práctica de la vida real para entender el control antes de entrar a la universidad.
- **2. Análisis de Aplicabilidad:** Evaluación de si aplica a la UNSA, si ya se cumple formal o parcialmente, y las razones legales de su situación.
- **3. Perspectiva Universidad (UNSA):** Plan de acción institucional con antecedentes, Portal de Transparencia del Estado y el modelo 5W (When, How, Who, What, Where).
- **4. Perspectiva del Auditor:** Liderazgo técnico del Ing. Rafael (MSc. Auditoría, 10 años de experiencia): diagnóstico GAP, checklist de verificación y dictamen formal.
- **5. Guiones de Exposición Oral:** Scripts listos para lectura o ponencia en clase con tono conversacional: uno como Universidad y otro como Auditor.

Matriz de Controles Analizados (Tabla A.1 ISO/IEC 27701:2025):

Control	Título en Inglés (Norma)	Propósito del Control	Ubicación
A.1.2.2	Identify and document purpose	Identificar y documentar propósitos específicos	Pág. 3
A.1.2.3	Identify lawful basis	Identificar y demostrar la base legal del tratamiento	Pág. 4
A.1.2.4	Determine when and how consent is obtained	Determinar proceso formal para obtener consentimiento	Pág. 5
A.1.2.5	Obtain and record consent	Obtener y registrar evidencias verificables de consentimiento	Pág. 6
A.1.2.6	Privacy impact assessment	Evaluación de impacto en la privacidad (EIPD / PIA)	Pág. 7
A.1.2.7	Contracts with PII processors	Contratos y cláusulas con encargados (procesadores cloud/terceros)	Pág. 8
A.1.2.8	Joint PII controller	Acuerdos de co-responsabilidad con instituciones asociadas	Pág. 9
A.1.2.9	Records related to processing PII	Mantenimiento seguro de registros de privacidad de PII	Pág. 10

Control A.1.2.2 — Identify and document purpose

« Identificar y documentar el propósito del tratamiento »

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall identify and document the specific purposes for which the PII will be processed."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** Antes de recopilar cualquier dato personal, la entidad debe saber con exactitud PARA QUÉ lo quiere y ponerlo formalmente por escrito. No se puede recolectar datos 'por si acaso' o para fines vagos como 'mejoras generales'.
• ***Analogía de la vida real:*** *Si vas a un hospital por una fractura, te piden tu nombre, DNI y radiografía (propósito asistencial). Si te piden tus estados de cuenta bancaria o qué auto conduces, no hay propósito justificado. Cada dato debe tener su porqué anotado.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA DIRECTAMENTE — Nivel actual: PARCIALMENTE IMPLEMENTADO.**
• **Sustento técnico-legal:** La UNSA ya tiene inscritos bancos de datos ante la ANPD (Estudiantes, Biblioteca, Grados y Títulos, Seguridad, RRHH) y posee una política web. Sin embargo, no tiene un Registro de Actividades de Tratamiento (RAT) detallado proceso por proceso; los fines declarados son genéricos y no cubren todos los sistemas satélites.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN

• **Marco y Antecedentes Estatales:** *Ley 29733 (Art. 5 Principio de Finalidad), D.S. 016-2024-JUS, Ley de Transparencia N° 27806, Ley Universitaria 30220 y Directivas internas de OTI.*
• **WHEN (Cuándo):** De inmediato y continuo. Mapeo inicial en 90 días; revisiones semestrales alineadas a cada matrícula o lanzamiento de nuevos sistemas.
• **HOW (Cómo):** 1. Levantar inventario de procesos universitarios con PII. 2. Diseñar plantilla RAT. 3. Mapear cada dato a su fin. 4. Aprobar vía Resolución Rectoral. 5. Publicar en Portal de Transparencia.
• **WHO (Quién):** Lidera OTI con Asesoría Jurídica. Apoyan Decanos, Admisión, RRHH y Bienestar. Aprueba el Rector (RR). Supervisa OCI.
• **WHAT (Qué entregables):** 1. Documento maestro RAT. 2. Política de Privacidad actualizada. 3. Resolución Rectoral. 4. Fichas de finalidad en formularios.
• **WHERE (Dónde se ubica):** Portal de Transparencia Estándar, web oficial (unsa.edu.pe), módulo SISUNSA y módulos de mesa de partes física.

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — ESTADO: Parcialmente Implementado | RIESGO: MEDIO

• **Observaciones de Auditoría:** La universidad posee trámites ante la ANPD pero carece de un inventario maestro centralizado de finalidades. En facultades se solicitan datos en formularios web sin ficha informativa.
• **Recomendaciones de Remediación:** Emitir el RAT consolidado mediante Resolución Rectoral, publicar fichas informativas de finalidad en formularios de admisión y matrícula, y capacitar a jefes de departamento.

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.2.2

• **Guión Como Universidad (UNSA):** *"Compañeros y profesor: Para implementar el A.1.2.2, la UNSA debe documentar para qué usa cada dato de sus 25,000 miembros. Ya tenemos bancos en el MINJUSDH, pero con fines muy vagos. Proponemos crear el RAT institucional, aprobarlo por Resolución Rectoral y publicar avisos claros en el Portal de Transparencia y en cada matrícula."*
• **Guión Como Auditor (Ing. Rafael):** *"Como auditor líder, califico este control como PARCIALMENTE IMPLEMENTADO (Riesgo MEDIO). La UNSA tiene avances ante la ANPD pero falla en granularidad técnica: admisión y bienestar piden datos sin exhibir la finalidad al titular. Recomiendo aprobar el RAT en 60 días bajo apercibimiento de observación formal."*

Control A.1.2.3 — Identify lawful basis

« Identificar y demostrar la base legal del tratamiento »

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall determine, document and be able to demonstrate compliance with the relevant lawful basis for the processing of PII for the identified purposes."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** No basta tener un motivo (A.1.2.2); debes demostrar QUÉ NORMA LEGAL te faculta jurídicamente para usar esos datos: si actúas por mandato de ley, contrato, función pública o consentimiento del titular.
• ***Analogía de la vida real:*** *Un policía no puede revisar tu mochila solo porque 'quiere verificar seguridad'; necesita una orden judicial, flagrancia o ley expresa. Si no tiene ese respaldo normativo, su acto es nulo.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA DIRECTAMENTE — Nivel actual: NO IMPLEMENTADO (Formalmente).**
• **Sustento técnico-legal:** Al ser universidad pública, la UNSA goza de la excepción del Art. 14 inc. 1 de la Ley 29733 (funciones públicas de la Ley 30220). Esa base legal EXISTE en la ley, pero la UNSA no la tiene formalizada ni documentada en una Matriz de Bases Legales ni en sus contratos de matrícula.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN

• **Marco y Antecedentes Estatales:** *Ley 29733 (Art. 13 y 14), D.S. 016-2024-JUS, Ley Universitaria 30220 (Art. 98-102), TUO Ley 27444 y resoluciones vinculantes de la ANPD.*
• **WHEN (Cuándo):** Fase de diseño del PIMS (primeros 60 días). Actualización obligatoria ante reformas legales del Congreso, MINJUSDH o SUNEDU.
• **HOW (Cómo):** 1. Elaborar Matriz de Bases Legales asociando cada proceso del RAT a su artículo normativo. 2. Diferenciar función pública de consentimiento forzoso. 3. Emitir Directiva Legal Rectoral.
• **WHO (Quién):** Oficina de Asesoría Jurídica de la UNSA como líder sustantivo, en coordinación con OTI y Secretaría General. Valida el Auditor.
• **WHAT (Qué entregables):** 1. Matriz Institucional de Bases Legales. 2. Informe Técnico Legal vinculante. 3. Cláusulas de base legal insertadas en reglamentos académicos.
• **WHERE (Dónde se ubica):** Oficina de Asesoría Jurídica, anexos del Reglamento General de la UNSA, y publicado en el Portal de Transparencia Estándar.

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — ESTADO: No Implementado | RIESGO: ALTO

• **Observaciones de Auditoría:** Existe la creencia errónea en las dependencias de que 'por ser universidad estatal podemos pedir cualquier dato'. No existe un documento formal que mapee los artículos legales habilitantes.
• **Recomendaciones de Remediación:** Aprobar la Matriz de Bases Legales por Consejo Universitario y capacitar a asesoría jurídica y personal de sistemas para fundamentar cada recolección de datos.

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.2.3

• **Guión Como Universidad (UNSA):** *"Para el control A.1.2.3, la universidad tiene que respaldar jurídicamente todo lo que hace. En Perú, el Art. 14.1 de la Ley 29733 nos permite tratar datos académicos sin consentimiento por función pública. Pero debemos DOCUMENTARLO: si la UNSA comparte notas de un alumno mayor de edad con sus padres, cometería una infracción si no tiene consentimiento."*
• **Guión Como Auditor (Ing. Rafael):** *"Dictamino este control como NO IMPLEMENTADO (Riesgo ALTO). La UNSA asume tácitamente que la Ley Universitaria lo cubre todo, pero carece de trazabilidad documental. Si la ANPD inspecciona, la universidad no tiene cómo probar qué base jurídica legitima datos de salud o biometría. Se exigen 45 días para la Matriz."*

Control A.1.2.4 — Determine when and how consent is to be obtained

« Determinar cuándo y cómo se debe obtener el consentimiento »

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall determine and document a process by which it can demonstrate if, when and how consent for the processing of PII was obtained from PII principals."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** Para los tratamientos donde la ley te exige autorización, debes tener un PROCEDIMIENTO formal: en qué momento exacto se pide, qué palabras se usan, qué casillas se marcan y cómo se demuestra que aceptaron libremente.
• ***Analogía de la vida real:*** *Cuando firmas un consentimiento antes de donar sangre o una cirugía, la clínica tiene un protocolo estricto: te explican los riesgos, firmas un documento específico y te dan copia. No dan por sentado tu sí.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA DIRECTAMENTE — Nivel actual: NO IMPLEMENTADO.**
• **Sustento técnico-legal:** Aplica para tratamientos que exceden las atribuciones de la Ley 30220: fotos en redes sociales de la UNSA, convenios internacionales con terceros, y tratamientos de datos sensibles en el comedor y tópico de bienestar universitario.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN

• **Marco y Antecedentes Estatales:** *Ley 29733 (Art. 13 - Consentimiento libre, previo, expreso, informado e inequívoco), D.S. 016-2024-JUS (prohibición de casillas premarcadas).*
• **WHEN (Cuándo):** Previo al inicio de cada ciclo académico y de forma permanente en cada formulario donde se recaben autorizaciones.
• **HOW (Cómo):** 1. Mapear casos de consentimiento obligatorio. 2. Diseñar flujogramas de captura. 3. Redactar textos claros sin letra chica. 4. Prohibir casillas premarcadas. 5. Definir mecanismos de revocación.
• **WHO (Quién):** OTI (arquitectura de software) + Asesoría Jurídica (cláusulas) + Dirección de Bienestar y Comunicación Social.
• **WHAT (Qué entregables):** 1. Procedimiento Operativo Estándar (POE) de Consentimiento. 2. Plantillas normalizadas de consentimiento informado. 3. Mecanismo de revocatoria.
• **WHERE (Dónde se ubica):** Sistemas informáticos académicos (SISUNSA, Portal del Postulante), módulos de tópico médico y portal web.

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — ESTADO: No Implementado | RIESGO: ALTO

• **Observaciones de Auditoría:** En eventos académicos y ferias se capturan datos de estudiantes mediante formularios de Google Forms sin texto de consentimiento informado ni opciones de opt-in.
• **Recomendaciones de Remediación:** Estandarizar todas las interfaces web con mecanismos de consentimiento explícito e incorporar procedimiento de revocatoria en el portal institucional.

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.2.4

• **Guión Como Universidad (UNSA):** *"El control A.1.2.4 nos exige definir las reglas del juego para pedir consentimiento. Cuando un estudiante se atiende en el tópico médico o la UNSA usa fotos para publicidad, debemos pedir permiso previo, libre e informado, con casillas desmarcadas y formularios claros. Además, el alumno debe poder revocar su autorización fácilmente."*
• **Guión Como Auditor (Ing. Rafael):** *"Constato informalidad respecto a este control: NO IMPLEMENTADO (Riesgo ALTO). Se recopilan datos en diplomados y ferias mediante formularios sin cláusulas de consentimiento. Esto constituye No Conformidad Mayor bajo ISO 27701. Ordeno suspender formularios no homologados hasta estandarizar el flujo conforme al D.S. 016-2024-JUS."*

Control A.1.2.5 — Obtain and record consent

« Obtener y registrar el consentimiento otorgado »

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall obtain and record consent from PII principals according to the documented processes."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** Si el control anterior era 'diseñar el método', este control es EJECUTARLO y GUARDAR LA EVIDENCIA. Debes conservar registros inalterables que prueben quién aceptó, a qué hora, qué versión leyó y qué IP o firma usó.
• ***Analogía de la vida real:*** *No basta tener un contrato de alquiler redactado; tienes que tenerlo firmado por el inquilino y archivado bajo llave para cuando necesites probarlo ante un juez.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA DIRECTAMENTE — Nivel actual: NO IMPLEMENTADO.**
• **Sustento técnico-legal:** Aplica para todos los sistemas de la UNSA donde se capture consentimiento. Si un estudiante denuncia ante la ANPD que no autorizó el uso de su imagen o historial médico, la UNSA debe presentar el log digital o el papel firmado.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN

• **Marco y Antecedentes Estatales:** *Ley 29733 (Principio de Responsabilidad Proactiva / Accountability), D.S. 016-2024-JUS y directivas de seguridad digital de OTI.*
• **WHEN (Cuándo):** En tiempo real al momento de la interacción del usuario y custodia durante al menos 5 años posteriores a la desvinculación.
• **HOW (Cómo):** 1. Implementar tabla 'Consent_Logs' (ID usuario, versión, timestamp, IP, hash). 2. Archivar consentimientos médicos escaneados. 3. Registrar bajas por revocatoria.
• **WHO (Quién):** Administradores de bases de datos y seguridad TI (OTI), personal de ventanilla de archivo, Oficial de Protección de Datos.
• **WHAT (Qué entregables):** 1. Base de datos centralizada de trazas y consentimientos digitales. 2. Repositorio de consentimientos físicos foliados. 3. Reporte de auditoría de revocatorias.
• **WHERE (Dónde se ubica):** Servidores de base de datos institucionales con respaldos encriptados; archivo físico en Secretaría General y Bienestar.

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — ESTADO: No Implementado | RIESGO: ALTO

• **Observaciones de Auditoría:** La universidad no dispone de tablas de auditoría de consentimientos en sus bases de datos. Los consentimientos en papel de bienestar se encuentran dispersos sin indexación.
• **Recomendaciones de Remediación:** Desarrollar un servicio centralizado de registro de consentimientos (API interna) y digitalizar de inmediato los expedientes físicos existentes.

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.2.5

• **Guión Como Universidad (UNSA):** *"Para el control A.1.2.5, la universidad tiene que guardar la prueba irrefutable de que el estudiante aceptó. Guardamos en el servidor fecha, hora, dirección IP y el texto exacto aceptado. Si fue en papel en el tópico médico, se archiva y escanea. Así, ante cualquier fiscalización, la UNSA demuestra pleno respeto a los derechos del titular."*
• **Guión Como Auditor (Ing. Rafael):** *"Declaro el estado de NO IMPLEMENTADO con riesgo ALTO. Al auditar una muestra de 10 alumnos al azar, el sistema no arrojó registros de auditoría con marca de tiempo ni trazabilidad de consentimiento. Esto deja a la UNSA en completa indefensión ante denuncias sancionables de la ANPD. Se exige log inmutable en 30 días."*

Control A.1.2.6 — Privacy impact assessment

« Evaluación de impacto en la privacidad (EIPD / PIA) »

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall assess the need for, and implement where appropriate, a privacy impact assessment whenever new processing of PII or changes to existing processing of PII is planned."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** Antes de crear un sistema nuevo o hacer un cambio tecnológico que use datos personales, debes hacer un 'estudio de riesgos de privacidad' para saber si vulneras derechos y cómo evitar filtraciones o abusos.
• ***Analogía de la vida real:*** *Es como el Estudio de Impacto Ambiental previo a construir una carretera: primero calculas el daño potencial al entorno y diseñas medidas mitigadoras antes de colocar la primera piedra.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA DIRECTAMENTE — Nivel actual: NO IMPLEMENTADO.**
• **Sustento técnico-legal:** Aplica con carácter de urgencia. La UNSA cuenta con proyectos de cámaras con reconocimiento biométrico, sistemas de asistencia docente y plataformas cloud. Todo proyecto tecnológico universitario con datos sensibles requiere EIPD.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN

• **Marco y Antecedentes Estatales:** *Guías de la ANPD sobre Evaluación de Impacto en Protección de Datos Personales, Directivas de Seguridad Digital de la PCM e ISO 31000.*
• **WHEN (Cuándo):** Fase de análisis y diseño de cualquier proyecto de software o infraestructura de TI, ANTES de la compra de equipos o pase a producción.
• **HOW (Cómo):** 1. Definir umbrales de obligatoriedad (biometría, salud, IA, cámaras). 2. Describir flujos de datos. 3. Evaluar necesidad/proporcionalidad. 4. Analizar riesgos y definir medidas.
• **WHO (Quién):** Equipo de Desarrollo de Software / OTI junto con Oficial de Datos (DPO) y Asesoría Jurídica. Aprueba Comité de Gobierno Digital.
• **WHAT (Qué entregables):** 1. Metodología Institucional de EIPD / PIA. 2. Informes de EIPD firmados por proyecto. 3. Matriz de riesgos de privacidad actualizada.
• **WHERE (Dónde se ubica):** Oficina de Tecnologías de la Información, Comité de Gobierno Digital y carpeta técnica de cada proyecto de inversión en TI.

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — ESTADO: No Implementado | RIESGO: ALTO

• **Observaciones de Auditoría:** La UNSA adquirió e instaló cámaras de videovigilancia y sistemas de control biométrico sin haber elaborado un análisis previo de impacto a la privacidad de los estudiantes y docentes.
• **Recomendaciones de Remediación:** Aprobar la directiva de EIPD obligatoria y ejecutar evaluaciones de impacto retroactivas para los sistemas de biometría y videovigilancia actualmente activos.

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.2.6

• **Guión Como Universidad (UNSA):** *"El control A.1.2.6 es el 'estudio de impacto ambiental' de los datos personales. En la UNSA solemos comprar servidores o cámaras pensando solo en la parte técnica. Con este control, antes de lanzar un nuevo sistema como el reconocimiento facial o inteligencia artificial, debemos evaluar si hay peligro de filtración y mitigar los riesgos."*
• **Guión Como Auditor (Ing. Rafael):** *"Punto crítico calificado como NO IMPLEMENTADO (Riesgo ALTO). Implementar biometría y videovigilancia sin una EIPD previa vulnera las directrices de la ANPD e ISO 27701. Mi dictamen exige formalizar de inmediato la metodología de EIPD e incorporarla como requisito insubsanable en las bases de licitación de TI."*

Control A.1.2.7 — Contracts with PII processors

« Contratos con encargados del tratamiento de PII (Processors) »

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall have a written contract with any PII processor that it uses, and shall ensure that their contracts with PII processors address the implementation of the appropriate controls in Annex A (see Table A.2)."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** Si contratas a una empresa externa para procesar datos por ti (Google para correo, hosting, soporte de ERP o seguridad física), debes firmar un contrato que les exija proteger los datos y no usarlos para fines propios.
• ***Analogía de la vida real:*** *Si le das las llaves de tu casa a una empresa de limpieza, firmas un contrato donde dice que solo limpian de 9 a 12, que no revisan cajones y que responden si rompen algo. No les das acceso sin límites.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA DIRECTAMENTE — Nivel actual: PARCIALMENTE IMPLEMENTADO.**
• **Sustento técnico-legal:** La UNSA usa Google Workspace, Microsoft 365, plataformas cloud y empresas de vigilancia. Aunque existen contratos OSCE estándar, la mayoría NO incluye los Anexos de Protección de Datos (DPA) exigidos por la ISO 27701.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN

• **Marco y Antecedentes Estatales:** *Ley 29733 (Art. 16 - Encargo del Tratamiento), D.S. 016-2024-JUS, Ley de Contrataciones del Estado (OSCE) y cláusulas tipo internacionales.*
• **WHEN (Cuándo):** En bases de licitación, contratación y renegociación contractual de cualquier proveedor que acceda a bases de datos.
• **HOW (Cómo):** 1. Identificar proveedores encargados. 2. Diseñar Adenda Estándar de Protección de Datos. 3. Incluir penalidades por brechas. 4. Exigir auditorías al proveedor. 5. Homologar DPAs.
• **WHO (Quién):** Oficina de Abastecimiento y Logística, Asesoría Jurídica y OTI. Aprueba la Dirección General de Administración (DGA).
• **WHAT (Qué entregables):** 1. Cláusula tipo obligatoria de protección de datos en TDRs. 2. Adendas de privacidad suscritas con proveedores. 3. Matriz de encargados.
• **WHERE (Dónde se ubica):** Expedientes de contratación en Logística, SEACE y archivo de Asesoría Jurídica.

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — ESTADO: Parcialmente Implementado | RIESGO: MEDIO-ALTO

• **Observaciones de Auditoría:** Los contratos con proveedores locales de mantenimiento de software y servicios de seguridad física no contienen ninguna cláusula de confidencialidad o tratamiento conforme a Ley 29733.
• **Recomendaciones de Remediación:** Elaborar de inmediato un anexo contractual de protección de datos y remitirlo a todos los proveedores tecnológicos y de servicios de la universidad para firma obligatoria.

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.2.7

• **Guión Como Universidad (UNSA):** *"Para el control A.1.2.7, nos enfocamos en los proveedores externos de la UNSA: Google, Microsoft, proveedores de ERP y empresas de vigilancia. La norma nos exige contratos escritos donde se estipule que los datos pertenecen a la UNSA, que no pueden revenderlos y que deben aplicar medidas de seguridad estrictas."*
• **Guión Como Auditor (Ing. Rafael):** *"La UNSA tiene contratos aprobados bajo la Ley OSCE pero vacíos en materia de privacidad: PARCIALMENTE IMPLEMENTADO (Riesgo MEDIO-ALTO). Si un proveedor sufre un hackeo, la UNSA es responsable solidaria por negligencia contractual. Exijo incorporar cláusulas DPA en todos los contratos vigentes en 60 días."*

Control A.1.2.8 — Joint PII controller

« Responsable conjunto de PII (Co-responsabilidad) »

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall determine respective roles and responsibilities for the processing of PII (including PII protection and security requirements) with any joint PII controller."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** Cuando dos instituciones deciden JUNTAS qué hacer con una base de datos (por ejemplo, dos universidades en investigación compartida o doble titulación), deben firmar un acuerdo donde se defina quién responde por qué.
• ***Analogía de la vida real:*** *Si dos socios abren un negocio y usan la misma lista de clientes, deben firmar un pacto donde diga quién cuida el archivo, quién atiende reclamos y cómo se reparten las culpas si hay una filtración. Nadie puede desentenderse.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA DIRECTAMENTE — Nivel actual: NO IMPLEMENTADO.**
• **Sustento técnico-legal:** La UNSA mantiene convenios de doble titulación con universidades extranjeras, proyectos de investigación con CONCYTEC/ProCiencia, consorcios (UNSA-UNI-San Marcos) e intercambios donde ambas partes deciden fines y medios.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN

• **Marco y Antecedentes Estatales:** *Convenios marco y específicos de cooperación académica, Ley 29733 (corresponsabilidad solidaria) y convenios con MINEDU y SUNEDU.*
• **WHEN (Cuándo):** En la negociación y firma de cualquier convenio interinstitucional o consorcio de investigación científica.
• **HOW (Cómo):** 1. Mapear convenios activos con transferencia o co-gestión de datos. 2. Diseñar Anexo de Co-Responsabilidad. 3. Asignar quién atiende derechos ARCO. 4. Fijar canal de incidentes.
• **WHO (Quién):** Oficina de Relaciones Internacionales y Cooperación (ORIC), Vicerrectorado de Investigación (VRI), Asesoría Jurídica y DPO.
• **WHAT (Qué entregables):** 1. Protocolo de Co-Responsabilidad para Convenios. 2. Cláusulas bilaterales de privacidad en convenios. 3. Matriz de corresponsabilidades.
• **WHERE (Dónde se ubica):** Oficina de Relaciones Internacionales, convenios en Secretaría General y portal de transparencia de convenios.

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — ESTADO: No Implementado | RIESGO: MEDIO

• **Observaciones de Auditoría:** Los convenios interuniversitarios de investigación y movilidad no delimitan quién es responsable ante una pérdida de datos personales ni quién asume la respuesta a solicitudes ARCO de los beneficiarios.
• **Recomendaciones de Remediación:** Crear una adenda modelo de co-responsabilidad y aplicarla a todos los convenios con intercambio de bases de datos de estudiantes o investigadores.

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.2.8

• **Guión Como Universidad (UNSA):** *"El control A.1.2.8 aplica cuando la UNSA trabaja en equipo con otras universidades: doble titulación o proyectos médicos con CONCYTEC. Ambas partes son 'responsables conjuntos'. Este control nos exige firmar un anexo donde se defina quién custodia los datos, quién atiende reclamos y qué hacer si ocurre un incidente de seguridad."*
• **Guión Como Auditor (Ing. Rafael):** *"Constato convenios de cooperación activos sin cláusulas de roles de privacidad: NO IMPLEMENTADO (Riesgo MEDIO). Si los datos de nuestros becarios en el extranjero se filtran, se genera un conflicto de responsabilidades. Recomiendo que ningún convenio con bases de datos sea suscrito sin la visa previa del Oficial de Datos."*

Control A.1.2.9 — Records related to processing PII

« Registros relacionados con el tratamiento de PII (Custodia y Evidencia) »

TEXTO NORMATIVO ISO/IEC 27701:2025:
"The organization shall determine and securely maintain the necessary records in support of its obligations for the processing of PII."

1. EXPLICACIÓN GENERAL DEL CONTROL (Concepto Universal)

• **¿Qué significa en lenguaje sencillo?:** Este control es el archivo y biblioteca de la privacidad: debes guardar, organizar y proteger con máxima seguridad todos los documentos generados por los controles anteriores (el RAT, consentimientos, contratos, evaluaciones de impacto y reclamos ARCO).
• ***Analogía de la vida real:*** *Es como el archivo contable de una empresa: guardas cada factura, boleta, libro mayor y balance bajo llave y en digital. Si viene la SUNAT a auditarte de sorpresa, tienes todas las carpetas listas para exhibir.*

2. ¿APLICA EN LA UNSA Y CUÁL ES SU ESTADO ACTUAL?

• **Diagnóstico de Aplicabilidad: APLICA DIRECTAMENTE — Nivel actual: PARCIALMENTE IMPLEMENTADO.**
• **Sustento técnico-legal:** La UNSA genera resoluciones rectorales, actas y contratos en su sistema de trámite documentario. Sin embargo, no tiene un sistema centralizado de registros de privacidad de PII; la información está fragmentada y no cuenta con políticas de retención y destrucción segura.

3. PERSPECTIVA DE LA UNIVERSIDAD (UNSA) — IMPLEMENTACIÓN

• **Marco y Antecedentes Estatales:** *Ley 29733 (Principio de Seguridad y Calidad), D.S. 016-2024-JUS (conservación y trazabilidad) y Ley del Sistema Nacional de Archivos.*
• **WHEN (Cuándo):** De forma continua. Almacenamiento activo durante el ciclo de vida del dato más el periodo legal de retención (mínimo 5 años para fiscalización de la ANPD).
• **HOW (Cómo):** 1. Crear Repositorio Seguro de Privacidad. 2. Aplicar controles de acceso por roles (RBAC). 3. Cifrar registros digitales. 4. Redactar Política de Retención y Disposición. 5. Auditorías semestrales.
• **WHO (Quién):** Oficial de Protección de Datos (DPO) con Archivo Central de la UNSA, OTI (seguridad digital) y OCI.
• **WHAT (Qué entregables):** 1. Catálogo Maestro de Registros de PII. 2. Repositorio Digital Cifrado con control de versiones. 3. Política de Retención y Destrucción Segura. 4. Bitácora de incidentes.
• **WHERE (Dónde se ubica):** Servidores de almacenamiento seguro de OTI con cifrado en reposo; Archivo Central de la UNSA con control de incendios y accesos.

4. PERSPECTIVA DEL AUDITOR (Ing. Rafael) — ESTADO: Parcialmente Implementado | RIESGO: ALTO

• **Observaciones de Auditoría:** Los documentos de privacidad están dispersos: resoluciones en Secretaría General, contratos en Logística y formularios en Bienestar. No existe un índice maestro ni medidas de seguridad específicas.
• **Recomendaciones de Remediación:** Implementar un módulo digital centralizado de gestión documental de privacidad PIMS y formalizar la política de retención y expurgo seguro aprobada por Consejo Universitario.

5. GUIONES DE EXPOSICIÓN ORAL — CONTROL A.1.2.9

• **Guión Como Universidad (UNSA):** *"Llegamos al control A.1.2.9, que es el 'paraguas' de todo el sistema. Si no guardamos registros ordenados y seguros, lo anterior no se puede demostrar. La UNSA debe crear un Repositorio Central de Privacidad donde estén organizados el RAT, las bases legales, las EIPD y los contratos, respaldados y cifrados para cualquier auditoría."*
• **Guión Como Auditor (Ing. Rafael):** *"Cierro mi dictamen con el A.1.2.9: PARCIALMENTE IMPLEMENTADO (Riesgo ALTO). En auditoría ISO, 'lo que no está documentado y accesible, no existe'. La documentación de la UNSA está atomizada sin política de retención ni garantías de confidencialidad. Exijo consolidar el Repositorio de Registros de Privacidad en un plazo de 90 días."*

Dictamen Global de Auditoría y Hoja de Ruta de Implementación

Tras la evaluación técnica de los 8 controles de la Tabla A.1 de la norma ISO/IEC 27701:2025 aplicada a la Universidad Nacional de San Agustín (UNSA), el auditor líder Ing. Rafael emite el siguiente dictamen consolidado. La universidad evidencia cumplimiento normativo sectorial incipiente (inscripción de bancos ante la ANPD), pero carece de un Sistema de Gestión de Privacidad de la Información (PIMS) estructurado y documentado conforme al estándar internacional.

Control	Nombre del Control (ISO 27701)	Estado de Madurez	Nivel Riesgo	Prioridad
A.1.2.2	Identify and document purpose	Parcialmente Implementado	MEDIO	Alta (P1)
A.1.2.3	Identify lawful basis	No Implementado	ALTO	Alta (P1)
A.1.2.4	Determine when/how consent obtained	No Implementado	ALTO	Media (P2)
A.1.2.5	Obtain and record consent	No Implementado	ALTO	Media (P2)
A.1.2.6	Privacy impact assessment	No Implementado	ALTO	Alta (P1)
A.1.2.7	Contracts with PII processors	Parcialmente Implementado	MEDIO-ALTO	Media (P2)
A.1.2.8	Joint PII controller	No Implementado	MEDIO	Baja (P3)
A.1.2.9	Records related to processing	Parcialmente Implementado	ALTO	Alta (P1)

Hoja de Ruta Recomendada de Implementación (12 Meses):

- **Fase 1 (Meses 1 a 3): Fundación Documental:** Formalización del RAT (A.1.2.2) y Matriz de Bases Legales (A.1.2.3) vía Resolución Rectoral; actualización de avisos en el Portal de Transparencia.
- **Fase 2 (Meses 4 a 6): Gobernanza de Terceros y Riesgo:** Incorporación de adendas DPA a contratos con proveedores clave (A.1.2.7), metodología de EIPD para proyectos nuevos (A.1.2.6) y acuerdos de convenios (A.1.2.8).
- **Fase 3 (Meses 7 a 9): Soluciones Tecnológicas y Consentimiento:** Implementación de base de datos de logs de consentimiento (A.1.2.4 y A.1.2.5) y repositorio cifrado de registros (A.1.2.9).
- **Fase 4 (Meses 10 a 12): Auditoría de Certificación y Cultura:** Capacitación masiva a facultades y dependencias administrativas, simulacro de fiscalización ANPD y auditoría interna ISO 19011.

FIRMA Y RESPONSABILIDAD TÉCNICA DEL AUDITOR LÍDER:

Ing. Rafael — Especialista en Ciberseguridad y Auditoría TI (MSc.) | Lead Auditor ISO/IEC 27001 & 27701